Análise de produto e negócio · 30 de outubro de 2026

Relatório de oportunidades

Controle de Gastos / Verbas

Repositório: `Arthur-MARKOWICZ/Controle_de_Gastos`

Branch analisada: **main** @ `0629907` (local atrás de origin/main em 7 commits)

Objetivo: mapear oportunidades acionáveis sustentadas por evidências do repositório, priorizá-las e apoiar decisões de roadmap — sem alterar código nem criar issues nesta etapa.

> **Escopo desta entrega:** análise + PDF. Issues no GitHub só após aprovação explícita por ID (OPP-XXX).

1. Resumo executivo

O produto já ultrapassou o “esqueleto”: autenticação (e-mail/senha, MFA TOTP, OAuth Google/GitHub), renda mensal, verbas com cinco naturezas, ledger com saldo negativo permitido, histórico editável, relatórios CSV/XLSX, web (Next.js) e mobile Android em paridade funcional parcial. O posicionamento implícito na UI é **Verbas — dinheiro com destino claro**.

Principais conclusões:

1. **Há bloqueio de abertura pública documentado:** direitos do titular (exportação/correção/exclusão), canal publicado e revisão jurídica ainda não implementados/fechados; o módulo `privacy` existe só como pacote Modulith vazio.
2. **A proposta de valor “verbas compartilhadas” ainda não existe na API nem nos clientes** — módulo `sharing` vazio; README admite ausência de endpoints.
3. **A hipótese central de hábito diário não foi validada** (checklist aberto em fundação técnica); há empty states, mas não um onboarding guiado renda → verbas → primeiro gasto, nem notificações.
4. **Identidade está madura para uso pessoal/privado**, porém cadastro não verifica e-mail de imediato (só via recuperação de senha) — risco se o cadastro for aberto.
5. **Nome público e domínio permanecem questões abertas**, enquanto a tela de auth já usa a marca “Verbas”.

Decisões que precisam ser tomadas: (a) o próximo marco é uso privado contínuo ou preparação para terceiros? (b) compartilhamento entra antes ou depois de LGPD operacional? (c) quais OPP-XXX viram issues agora?

2. Escopo e metodologia

Áreas inspecionadas

- Documentação de intenção, ADRs, privacidade, deploy e API OpenAPI.
- Estrutura Modulith do backend (módulos com e sem implementação).
- Clientes web e mobile (paridade e lacunas declaradas).
- Migrações Flyway V1–V12 e controllers REST existentes.
- Estado Git local e capacidade do `gh`.

Verificações executadas

- `git status --short --branch`, log recente, remote.
- Leitura de README, fundação técnica, ADRs-chave, requisitos LGPD, inventário de dados.
- Inventário de controllers, pacotes vazios e rotas OpenAPI.
- `gh auth status` / `gh issue list` (falhou: token inválido — issues existentes *não* puderam ser consultadas).

Não executado / limitações

- `make test` / `make check` não foram rodados nesta análise (evitar carga longa e dependência de infra sem necessidade para a análise de negócio).
- Sem entrevistas com usuários reais; premissas de adoção são hipóteses documentadas pelo próprio projeto.
- Sem acesso a métricas de uso, receita ou retenção (produto ainda sem modelo de monetização declarado).
- Conteúdo de `.env` não foi lido (menor privilégio).
- Branch local está 7 commits atrás de `origin/main`; oportunidades baseiam-se no estado local + docs.

3. Entendimento do produto

Fatos observados

- **Problema:** reservar renda em verbas acumuláveis, registrar gastos com pouco esforço, permitir saldo negativo com alerta, e (no desenho) compartilhar verbas com papéis assimétricos.
- **Canais:** mobile para lançamento rápido; web para configuração/histórico/relatórios; backend como fonte única de regras.
- **Stack:** monorepo; Spring Modulith; Next.js; KMP (Android validável; iOS não testado neste ambiente).
- **Implementado:** identity (incl. MFA e OAuth), income, envelopes, ledger, reporting; deploy Docker + Nginx/HTTPS documentado.
- **Não implementado (pacotes vazios):** sharing, notifications, audit, privacy.
- **Marca na UI web:** “Verbas” / “Dinheiro com destino claro” (`AuthScreen.tsx`).

Hipóteses (não comprovadas por uso)

- O lançamento manual é rápido o bastante para virar hábito diário.
- O modelo de dinheiro reservado é compreendido sem explicação extensa (há glossário, mas não há evidência de compreensão por usuários).
- Controle exclusivo do criador em verba compartilhada atenderá uso real (feature ainda inexistente).
- Público inicial: o próprio responsável pelo repositório e, depois, pessoas próximas — *hipótese*; público-alvo comercial não está fechado.

Estágio aparente

Produto pessoal avançado / pré-abertura pública: núcleo financeiro individual utilizável; lacunas estruturais em compartilhamento, notificações e direitos do titular.

4. Matriz priorizada de oportunidades

ID	Título	Pri.	Cat.	Esforço	Confiança	Decisão sugerida
OPP-001	Direitos do titular: exportar, corrigir e excluir conta	P0	Segurança/privacidade	L	Alta	Implementar antes de cadastro público
OPP-002	Canal do titular e política de privacidade publicados	P0	Segurança/privacidade	S	Alta	Implementar / publicar
OPP-003	Verificação de e-mail no cadastro	P1	Segurança / ativação	M	Alta	Implementar se houver abertura a terceiros
OPP-004	Onboarding guiado até o primeiro gasto	P1	Ativação / UX	M	Média	Experimentar com uso próprio + 2–3 usuários
OPP-005	Compartilhamento de verbas (API + web + mobile)	P1	Produto	XL	Alta (necessidade no desenho); média (demanda real)	Validar demanda; depois ADR + corte vertical
OPP-006	Alertas de saldo negativo (in-app e/ou push)	P2	Retenção	L	Média	Começar por alerta in-app; push depois
OPP-007	Fechar nome público, domínio e posicionamento	P2	Aquisição / marca	S	Alta	Decidir agora se houver intenção de compartilhar URL
OPP-008	Auditoria detalhada de edições no ledger	P3	Confiabilidade / privacidade	L	Alta (dívida explícita)	Não fazer agora — ADR-009
OPP-009	Ciclo de validação das premissas de hábito e compreensão	P1	Produto / retenção	S	Média	Validar com usuários antes de features grandes

ID	Título	Pri.	Cat.	Esforço	Confiança	Decisão sugerida
OPP-010	Vínculo de provedor social na conta via mobile	P3	UX / paridade	M	Alta	Adiar — workaround na web existe

5. Detalhamento das oportunidades

OPP-001 — Direitos do titular: exportar, corrigir e excluir conta

P0 **Esforço L** · Categoria: segurança/privacidade · Confiança: alta

Problema: requisitos de privacidade exigem exportação, correção e exclusão com autenticação reforçada. Sem isso, abertura pública de cadastro viola a própria política do projeto.

Evidências:

- `docs/privacy/requisitos-de-seguranca.md` — seção “Direitos do titular”.
- `docs/ideas/fundacao-tecnica.md` — privacidade transversal inclui exportação/exclusão; revisão jurídica antes de abertura pública.
- Módulo `backend/.../privacy/` contém apenas `package-info.java`.
- OpenAPI listado não expõe endpoints de exclusão/exportação de conta (apenas relatórios financeiros).
- README alerta para não abrir cadastro ao público antes dos requisitos jurídicos/operacionais.

Recomendação: implementar no módulo `privacy` (ou identity+privacy) fluxos: exportação estruturada dos dados do titular, correção de e-mail com re-verificação, exclusão/anonimização com confirmação reforçada (senha/MFA), revogação de sessões e tokens. Atualizar inventário de dados e ADR se necessário.

Valor: desbloqueia uso por terceiros com conformidade mínima alinhada ao desenho; reduz risco jurídico/reputacional.

Métrica: checklist LGPD operacional 100% para o corte; tempo de atendimento a pedido de exclusão < prazo legal definido; zero contas sem caminho de exclusão.

Riscos: exclusão mal definida pode apagar evidências ou orphan records; exige política de retenção (ainda pendente em inventário para alguns campos).

Dependências: política de retenção; decisão sobre backups; MFA já existe (pode reforçar exclusão).

Primeiro passo / aceite: ADR curto + endpoint de exportação autenticada + endpoint de exclusão com confirmação; testes de autorização; inventário atualizado.

Decisão sugerida: implementar (bloqueio de abertura pública).

OPP-002 — Canal do titular e política de privacidade publicados

P0 Esforço S · Categoria: segurança/privacidade · Confiança: alta

Problema: o requisito exige canal eletrônico publicado e explicação acessível de finalidades. Sem página/contato, não há atendimento formal a titulares.

Evidências: `docs/privacy/requisitos-de-seguranca.md` (direitos do titular); runbook HTTPS menciona privacidade antes de abertura; não há rota web óbvia de política/contato no inventário de `web/src/app`.

Recomendação: publicar política em linguagem clara + e-mail/canal de contato no rodapé/auth e em configurações; registrar o procedimento de atendimento.

Valor: requisito mínimo e barato; habilita OPP-001 operacionalmente.

Métrica: URL pública acessível sem login; canal testado com mensagem de prova.

Riscos: texto sem revisão jurídica — marcar como “versão operacional” até parecer jurídico.

Decisão sugerida: implementar.

OPP-003 — Verificação de e-mail no cadastro

P1 Esforço M · Categoria: segurança / ativação · Confiança: alta

Problema: contas podem ser criadas com e-mails não controlados pelo usuário; spam de cadastro e recuperação frágil se o e-mail for falso.

Evidências: README: “O cadastro não verifica o e-mail imediatamente; uma recuperação de senha bem-sucedida o confirma”; campo `email_verified_at` em `UserAccount`; inventário confirma a mesma regra.

Recomendação: fluxo de verificação no cadastro (token de uso único), reutilizando infraestrutura de e-mail da recuperação (ADR-018). Opcionalmente restringir mutações financeiras até verificação.

Valor: qualidade de conta; base para comunicações e compartilhamento futuro.

Métrica: % de contas com `emailVerifiedAt` não nulo em N dias após cadastro.

Riscos: fricção de ativação; dependência de SMTP/Gmail confiável.

Decisão sugerida: implementar se houver terceiros; para uso só pessoal, prioridade menor.

OPP-004 — Onboarding guiado até o primeiro gasto

P1 **Esforço M** · Categoria: ativação / UX · Confiança: média

Problema: após o login, a visão geral exige compreender renda, tipos de verba e glossário. Empty states existem, mas o caminho “renda → primeira verba → primeiro gasto” não é um fluxo único guiado — risco de abandono na ativação.

Evidências: `Dashboard.tsx` (avisos de renda não configurada e empty state de verbas); glossário em dialog; premissa não marcada em `fundacao-tecnica.md` (“modelo compreendido sem explicação extensa”).

Recomendação: checklist/wizard de 3 passos no primeiro acesso (web e mobile), com copy que reutilize o glossário só no momento da escolha do tipo.

Valor: aumenta chance de o núcleo do produto ser experimentado no primeiro dia.

Métrica: % de novos usuários que registram ≥1 gasto em 24h (baseline a coletar).

Riscos: wizard pode irritar usuário avançado — permitir pular.

Decisão sugerida: experimento pequeno (validar com OPP-009).

OPP-005 — Compartilhamento de verbas

P1 **Esforço XL** · Categoria: produto · Confiança: alta no desenho; média na demanda

Problema: resultado confirmado da fundação inclui verbas compartilhadas (participantes veem/registram; só o criador abastece/convida/encerra). Hoje isso não existe — diferencial prometido vs. apps genéricos de gasto fica incompleto para casais/famílias.

Evidências: fundação técnica (resultado confirmado); README (sem endpoint em nenhum cliente); `sharing/package-info.java` vazio; OpenAPI sem rotas de convite/participante; ADR-007 menciona participantes na autorização.

Recomendação: validar com 3–5 possíveis co-usuários se o modelo assimétrico resolve o caso; se sim, ADR de compartilhamento + corte: convite por e-mail, papéis, autorização no ledger/reporting, UX web/mobile mínima.

Valor: completa a proposta de valor multi-pessoa; potencial de retenção viral leve (hipótese).

Métrica: nº de verbas com ≥1 participante ativo; gastos lançados por não-owners.

Riscos: complexidade de autorização e LGPD (dados de terceiros); escopo XL; depende de e-mail verificado (OPP-003).

Dependências: OPP-001/003 recomendáveis antes de convidar terceiros; ADR novo.

Decisão sugerida: validar demanda antes de construir o XL.

OPP-006 — Alertas de saldo negativo

P2 Esforço L · Categoria: retenção · Confiança: média

Problema: a regra de negócio permite gasto acima do saldo com alerta, mas o módulo de notificações está vazio e push depende de Firebase/APNs pendente. O “alerta” pode ficar só visual na sessão.

Evidências: fundação (mobile: alertas/notificações); `notifications` vazio; ADR-007 rejeita push para todo gasto e recomenda negativo/compartilhada com consentimento; questão aberta Firebase/APNs.

Recomendação: fase 1 — centro de alertas persistente in-app + e-mail opcional; fase 2 — push com opt-in após decisão de provedor.

Valor: reforça o loop de atenção sem bloquear o gasto real.

Métrica: % de eventos `isNegative` vistos/dispensados em ≤24h.

Riscos: custo/ops de push; spam se mal calibrado; LGPD (opt-in).

Decisão sugerida: investigar / fasear; não começar por Firebase.

OPP-007 — Nome público, domínio e posicionamento

P2 Esforço S · Categoria: aquisição / marca · Confiança: alta

Problema: fundação lista “nome público do produto” e domínio como questões abertas; a UI já usa “Verbas”, o repositório “Controle_de_Gastos” — inconsistência atrapalha comunicação e HTTPS por subdomínio.

Evidências: `fundacao-tecnica.md` questões abertas; `AuthScreen.tsx` marca “Verbas”.

Recomendação: decidir nome (ex.: Verbas), registrar domínio, alinhar README/app store futuro/subdomínio.

Valor: clareza de produto; base para qualquer aquisição.

Métrica: decisão documentada + URLs consistentes.

Decisão sugerida: decidir agora se houver URL compartilhada.

OPP-008 — Auditoria detalhada de edições no ledger

P3 Esforço L · Categoria: confiabilidade · Confiança: alta

Problema: edições/exclusões lógicas alteram totais históricos sem trilha de versões — dívida explícita.

Evidências: ADR-009 (adiamento aceito); módulo `audit` vazio.

Recomendação: manter adiamento até haver requisito de disputa entre participantes ou obrigação de rastreio; então novo ADR com retenção/exportação.

Decisão sugerida: não fazer agora.

OPP-009 — Ciclo de validação das premissas de produto

P1 **Esforço S** · Categoria: produto · Confiança: média

Problema: várias premissas críticas estão unchecked; construir sharing/push/iOS sem validá-las aumenta desperdício.

Evidências: checklist “Premissas a validar” em `fundacao-tecnica.md`.

Recomendação: protocolo de 2 semanas de uso pessoal instrumentado (diário simples: dias com lançamento, tempo até 1º gasto, dúvidas de tipos de verba) + 2 entrevistas curtas com possíveis usuários de verba compartilhada.

Valor: reduz risco de roadmap; alimenta OPP-004/005/006.

Métrica: premissas marcadas com evidência ou rejeitadas explicitamente.

Decisão sugerida: fazer agora (baixo custo).

OPP-010 — Vincular provedor social pelo mobile

P3 **Esforço M** · Categoria: UX · Confiança: alta

Problema: vincular Google/GitHub a conta existente só na web (limitação de token no browser do sistema).

Evidências: README — diferenças restantes.

Recomendação: adiar; documentar o caminho web na tela de segurança mobile.

Decisão sugerida: não fazer agora.

6. Riscos transversais e dependências

- **Abertura pública prematura:** README e docs de privacidade condicionam cadastro aberto a requisitos jurídicos/operacionais ainda incompletos (OPP-001/002/003).
- **Módulos fantasma:** sharing, notifications, audit, privacy reservados no Modulith sem comportamento — risco de falsa sensação de cobertura.
- **Autenticação GitHub CLI inválida nesta sessão:** impossível checar duplicatas de issues antes da Fase 6.
- **Branch local desatualizada:** 7 commits atrás de origin/main — revalidar oportunidades após atualizar.
- **Dependência de e-mail transacional:** recuperação e futura verificação/compartilhamento dependem de provedor estável.
- **iOS / push:** bloqueados por ambiente e decisões de provedor — não tratar como entregas próximas sem pré-requisitos.
- **Sem modelo de monetização:** roadmap deve otimizar utilidade e sustentabilidade operacional (VPS), não receita inventada.

7. O que não recomendo fazer agora

- **Microserviços, filas, Redis/cache, Kubernetes** — rejeitados pela fundação/AGENTS; sem evidência de necessidade.
- **Integração bancária / Open Finance** — fora de escopo explícito; alto custo LGPD e complexo.
- **IA para categorizar gastos** — sem evidência de dor; o produto valoriza registro consciente em verbas.
- **Push para todo gasto** — já rejeitado no ADR-007.
- **Produção iOS** — sem macOS/Xcode.
- **Keycloak no runtime atual** — ADR futuro se necessário; auth própria já cobre o corte.
- **Auditoria detalhada (OPP-008) e vínculo social mobile (OPP-010)** — dívida conhecida com workaround ou adiamento formal.
- **Monetização (assinatura/ads)** — prematuro sem base de usuários e sem fechamento de privacidade.

8. Plano sugerido (sem assumir aprovação)

Fase A — Uso seguro (privado / piloto fechado)

1. OPP-009: validar hábito e compreensão em uso real.
2. OPP-004: onboarding mínimo se a ativação falhar na observação.
3. OPP-007: fechar nome/domínio se for compartilhar URL.

Fase B — Preparar terceiros

1. OPP-002 + OPP-001 (política/canal + direitos do titular).
2. OPP-003 (verificação de e-mail).
3. Revisão jurídica (fora do código).

Fase C — Ampliar valor multi-pessoa

1. Validação qualitativa de OPP-005; se positiva, ADR + corte vertical de sharing.
2. OPP-006 fase 1 (alertas in-app) alinhado a sharing/negativo.

9. Decisões solicitadas

Para cada ID, responda com uma opção: **aprovar para issue**, **rejeitar**, **revisar** ou **investigar mais**.

ID	Título curto	Sua decisão
OPP-001	Exportar / excluir conta (LGPD)	_____
OPP-002	Canal + política de privacidade	_____
OPP-003	Verificação de e-mail	_____
OPP-004	Onboarding guiado	_____
OPP-005	Compartilhamento de verbas	_____
OPP-006	Alertas de saldo negativo	_____
OPP-007	Nome / domínio / marca	_____
OPP-008	Auditoria detalhada	_____
OPP-009	Validação de premissas	_____
OPP-010	OAuth link no mobile	_____

Importante: aprovação genérica deste PDF *não* autoriza criar todas as issues. Informe os IDs específicos. Também será necessário reautenticar o `gh` (`gh auth login`) antes da Fase 6.

10. Apêndice — evidências e referências

Documentos

- `docs/ideas/fundacao-tecnica.md`
- `docs/privacy/requisitos-de-seguranca.md`, `inventario-de-dados.md`
- `docs/decisions/0007-...`, `0009-...`, `0014-...`, `0018-...`, `0019-...`, `0020-...`
- `README.md`, `AGENTS.md`, `docs/api/openapi.yaml`

Código / estrutura

- Controllers: Auth, Mfa, OAuth, User, Income, Envelope, Ledger, History, Reporting.
- Pacotes vazios: `sharing`, `notifications`, `audit`, `privacy`.
- Migrações Flyway: V1–V12 (identity → income → envelopes → ledger → savings/annual → reset → MFA → OAuth).
- UI: `web/src/components/AuthScreen/AuthScreen.tsx`, `Dashboard/Dashboard.tsx`.
- Testes observáveis: ~42 classes Java de teste, ~21 testes web, ~9 testes Kotlin (contagem por nome de arquivo).

Ambiente da análise

- Data: 2026-10-30
- Git: branch main @ 0629907; status com skills novas untracked e 1 .class modificado.
- gh: instalado 2.103.3; autenticação inválida.
- PDF gerado via HTML + Chrome headless (reportlab não estava instalado; nenhuma dependência nova foi instalada no projeto).

Este artefato foi adicionado em `reports/`. Não inclui commit automático. Nenhuma issue foi criada. Nenhuma alteração de código de produto foi feita pela análise (apenas este relatório).